

— PACKAGE CLIENT COMPLET —

FLGB CONSEILS

Expert Sécurité · Sûreté · Cybersécurité

KIT CYBERSÉCURITÉ CLÉ EN MAIN

Votre programme complet sur 5 jours
pour sécuriser votre TPE/PME dès aujourd'hui

997 € HT | Investissement unique

Diagnostic · Plan d'action · Formation · Politique de sécurité · 30 j de suivi

François Louis-Guy Briar

25 ans de terrain | contact@flgb-conseils.fr

www.flgb-conseils.fr

SOMMAIRE

1	Lettre de bienvenue
2	Programme sur 5 jours
3	Guide — Les 5 Failles Cyber qui exposent votre TPE
3.1	Faille N°1 — Le mot de passe qui ouvre tout
3.2	Faille N°2 — Les mises à jour que personne ne fait
3.3	Faille N°3 — La sauvegarde qui ne sauve rien
3.4	Faille N°4 — L'email qui ressemble au vrai
3.5	Faille N°5 — Le smartphone qui trahit tout
3.6	Checklist d'urgence — 12 actions cette semaine
4	Kit Cybersécurité Clé en Main — Programme complet
4.1	Module 1 — Mode d'emploi et guide de lecture
4.2	Module 2 — Auto-diagnostic en 20 questions
4.3	Module 3 — Interprétation de votre score
4.4	Module 4 — 5 Fiches recommandations détaillées
4.5	Module 5 — Modèle Politique de Sécurité
4.6	Module 6 — Registre simplifié des traitements RGPD
4.7	Module 7 — Checklist conformité RGPD & NIS2
4.8	Module 8 — Que faire en cas d'incident cyber

Madame, Monsieur,

Je vous remercie pour votre confiance. En investissant dans le Kit Cybersécurité Clé en Main, vous faites aujourd'hui un choix concret pour protéger ce que vous avez mis des années à construire.

Ce kit a été conçu avec une conviction simple : la cybersécurité ne doit pas être réservée aux grandes entreprises avec des DSI et des budgets conséquents. En 25 ans de terrain, j'ai vu trop de TPE et PME touchées par des incidents qui auraient pu être évités avec les bons outils et les bons réflexes.

Ce que vous avez entre les mains, c'est exactement ce que je fais pour mes clients sur site — condensé en un programme autonome de 5 jours, que vous pouvez mettre en œuvre à votre rythme, dans votre structure, avec votre équipe.

Si vous bloquez sur un point, si une question se pose en cours de mise en œuvre, je reste disponible 30 jours après votre achat. Écrivez-moi directement : contact@flgb-conseils.fr

Bonne mise en œuvre,

François Louis-Guy Briar

Expert Sécurité · Sûreté · Cybersécurité
FLGB Conseils | contact@flgb-conseils.fr

30 jours de support inclus — Une question en cours de mise en œuvre ? Écrivez-moi :
contact@flgb-conseils.fr

2

Programme sur 5 jours

Ce que contient votre package

01

Kit Clé en Main — Document principal (Section 4)

Le cœur du programme. 8 modules, 20 questions de diagnostic, fiches recommandations, modèle de politique de sécurité, registre RGPD, checklist NIS2 et procédure d'incident.

02

Guide — Les 5 Failles Cyber (Section 3)

Le point de départ. Ce guide identifie les 5 erreurs les plus fréquentes dans les TPE françaises. Lisez-le en premier pour orienter votre diagnostic.

03

30 jours de support email

Accès direct à François Louis-Guy Briar pendant 30 jours. Pour toute question, blocage ou adaptation à votre situation spécifique. contact@flgb-conseils.fr

Votre programme jour par jour

J1 – J2

DIAGNOSTIC

Répondez aux 20 questions du Module 2. Calculez votre score /40 et identifiez vos priorités dans le tableau de synthèse.

J3

PLAN D'ACTION

Travaillez les fiches recommandations dans l'ordre de priorité défini par votre score. Chaque fiche est autonome et actionnable immédiatement.

J4

DOCUMENTS

Personnalisez la Politique de Sécurité (Module 5) et le Registre RGPD (Module 6) avec vos informations. Faites signer la



politique par vos collaborateurs.

J5

FORMATION

Utilisez les checklists NIS2/RGPD (Module 7) pour valider votre conformité. Organisez une session de 30 min avec votre équipe sur le phishing.

J30

SUIVI

Bilan à 30 jours. Vérifiez les points mis en œuvre, identifiez les ajustements nécessaires. Support email disponible jusqu'à cette date.



0 – 10 CRITIQUE	11 – 22 INTERMÉDIAIRE	23 – 33 CORRECT	34 – 40 AVANCÉ
--------------------	--------------------------	--------------------	-------------------

Grille de lecture de votre score /40

Pourquoi ce guide

Les cybercriminels ne ciblent pas seulement les grandes entreprises. Ils ciblent les systèmes mal protégés — et les TPE françaises sont parmi les plus vulnérables. Pas parce que vous êtes moins intelligents, mais parce que vous avez moins de moyens pour vous défendre, et que personne ne vous a encore dit où regarder.

Ce guide résume les 5 erreurs que l'on retrouve dans 9 TPE sur 10 lors des audits. Ce sont des failles simples, souvent corrigées en quelques heures — mais qui, non corrigées, peuvent coûter des dizaines de milliers d'euros.

60%

des PME victimes d'un
ransomware déposent le bilan
dans les 18 mois

18 000€

coût moyen d'une cyberattaque
pour une TPE française

1/5

TPE attaquée chaque année en
France

Sources : ANSSI, Rapport sur la menace informatique 2024 — Hiscox, Cyber Readiness Report 2024.

FAILLE
N°1

Le mot de passe qui ouvre tout

La faille la plus simple — et la plus exploitée. En moins de 2 minutes, un attaquant peut accéder à votre messagerie, votre comptabilité ou vos fichiers clients.

Ce qui se passe vraiment

Les hackers utilisent des attaques dites "par dictionnaire" ou "par force brute". Ils testent automatiquement des milliers de combinaisons à la seconde. Un mot de passe comme "Societe2023!" — que beaucoup croient sûr — est cassé en moins de 3 heures.

Pire : si vous utilisez le même mot de passe sur plusieurs services (messagerie, banque, cloud), une seule fuite suffit à tout compromettre. En 2024, plus de 8 milliards d'identifiants ont circulé sur le dark web.

Les signaux d'alerte chez vous

→ Vous utilisez le prénom d'un proche ou le nom de votre entreprise

- Votre mot de passe fait moins de 12 caractères
- Vous utilisez le même mot de passe sur plusieurs sites
- Vos collaborateurs partagent des identifiants communs
- Vous ne changez jamais vos mots de passe

CE QUE VOUS POUVEZ FAIRE CETTE SEMAINE

1. Installez une "boîte à mots de passe" sur votre téléphone et votre ordinateur.

C'est une application gratuite qui retient tous vos mots de passe à votre place — vous n'avez plus rien à mémoriser, ni à noter sur un post-it. Elle en génère des très solides automatiquement.

→ **Outil recommandé** : Bitwarden (gratuit, disponible en français sur téléphone et ordinateur).

2. Ajoutez un "deuxième verrou" sur votre messagerie professionnelle.

Quand vous vous connectez, votre téléphone reçoit un code à 6 chiffres que vous devez entrer. Même si quelqu'un vole votre mot de passe, il ne peut pas entrer sans votre téléphone.

→ Ça s'active en 5 minutes dans les paramètres de Gmail ou Outlook.

3. Vérifiez si vos mots de passe ont déjà été volés à votre insu.

Allez sur haveibeenpwned.com, tapez votre adresse email professionnelle. En 2 secondes, le site vous dit si vos identifiants figurent dans une liste de données volées.

→ **Gratuit, anonyme, 30 secondes.**

FAILLE

N°2

Les mises à jour que
personne ne fait

80% des cyberattaques exploitent des failles connues depuis des mois — et pour lesquelles des correctifs existent. Si vous ne les appliquez pas, votre système est une porte ouverte.

Pourquoi c'est critique

Quand un éditeur publie une mise à jour de sécurité, il révèle en même temps la faille qui vient d'être corrigée. Les hackers s'empressent alors d'exploiter cette faille sur tous les systèmes qui n'ont pas encore été mis à jour. Le délai entre la publication d'un correctif et son exploitation massive est en moyenne de 15 jours.

Les systèmes les plus souvent négligés dans les TPE : routeur WiFi (souvent jamais mis à jour), NAS de sauvegarde, logiciels de comptabilité, et téléphones professionnels sous Android.

Action immédiate

- Activez les mises à jour automatiques sur tous les postes Windows/Mac
 - Vérifiez la date du dernier firmware de votre routeur WiFi professionnel
 - Mettez à jour votre antivirus et vérifiez qu'il est actif sur tous les postes
 - Planifiez une heure par mois pour vérifier les mises à jour des logiciels métier
-

FAILLE

N°3

La sauvegarde qui ne sauve rien

Vous avez une sauvegarde. Mais dans 60% des cas, elle est inutilisable le jour où vous en avez vraiment besoin — parce qu'elle est incomplète, corrompue, ou chiffrée par le même ransomware qui a attaqué votre réseau.

Le cas réel qui se répète

Un cabinet comptable de Normandie. 12 salariés. Une sauvegarde quotidienne sur un disque externe connecté au serveur. En apparence, tout est en ordre. Un jour, un ransomware chiffre tous les fichiers du serveur. La sauvegarde aussi — parce qu'elle était connectée au même réseau. 3 semaines d'arrêt complet. 34 000€ de pertes directes. Des clients partis.

La règle d'or : la sauvegarde doit être déconnectée du système principal. Et vous devez la tester régulièrement en essayant de restaurer un fichier réel.

LA RÈGLE 3-2-1 3 copies de vos données — 2 supports différents — 1 copie hors site (cloud ou site distant). Exemple : fichiers sur votre serveur + sauvegarde sur disque externe déconnecté + sauvegarde automatique sur cloud chiffré (ex: Backblaze, ~9€/mois).

FAILLE

N°4

L'email qui ressemble au vrai

Le phishing est responsable de 91% des cyberattaques. Un email convaincant suffit pour qu'un collaborateur clique sur un lien, entre ses identifiants, ou valide un virement frauduleux.

Les 3 techniques les plus utilisées

Le phishing classique : un email imitant votre banque, votre fournisseur ou un prestataire vous demande de "valider votre compte". Le lien redirige vers un faux site qui vole vos identifiants.

Le spear phishing : l'attaquant a fait des recherches sur vous (LinkedIn, site web). L'email cite votre nom, votre client, un projet en cours. Il semble légitime. C'est le plus dangereux.

La fraude au virement (FOVI) : quelqu'un se fait passer pour votre dirigeant ou un fournisseur et demande un virement urgent sur un nouveau compte. Cette fraude coûte des millions chaque année aux TPE françaises.

Comment reconnaître un email suspect

- L'expéditeur est inconnu ou l'adresse ne correspond pas au domaine officiel
- L'objet crée une urgence ("Action requise", "Votre compte va être bloqué")
- On vous demande de cliquer sur un lien pour "confirmer" quelque chose
- Le lien dans l'email ne correspond pas au domaine réel (survolez avant de cliquer)
- On vous demande un virement ou un paiement inhabituels, même de la part de votre dirigeant

Règle d'or : tout virement ou changement de coordonnées bancaires doit être confirmé par téléphone au numéro habituel — jamais au numéro indiqué dans l'email.

FAILLE
N°5

Le smartphone qui trahit tout

Vos collaborateurs accèdent à leurs emails professionnels, vos fichiers et vos outils depuis leurs téléphones personnels. Sans aucune politique de sécurité. C'est une faille ouverte sur votre système entier.

Le problème concret

Un téléphone personnel, c'est aussi : des applications tierces non contrôlées, une connexion WiFi publique parfois utilisée, une mise à jour de l'OS souvent repoussée, et aucun effacement à distance possible si le téléphone est perdu. Si ce téléphone accède à votre messagerie professionnelle ou à votre Google Drive partagé, une application malveillante peut exfiltrer vos données sans que vous le sachiez.

Sur le plan juridique (RGPD), vous restez responsable des données clients traitées — même depuis un téléphone personnel. En cas de fuite, c'est votre entreprise qui répond devant la CNIL.

Ce qu'il faut mettre en place

- Politique BYOD ("Bring Your Own Device") claire : règles d'usage des téléphones perso
 - Accès aux emails pro via un client dédié avec authentification 2FA obligatoire
 - Séparation des données pro et perso (application MDM ou conteneur sécurisé)
 - Procédure de désactivation immédiate en cas de vol ou perte du téléphone
 - Formation de 30 minutes pour sensibiliser les équipes aux risques mobiles
-

Checklist d'urgence FLGB — 12 actions à réaliser cette semaine

Ces 12 actions ne nécessitent aucun budget particulier et peuvent être réalisées par n'importe quel dirigeant de TPE.

MOTS DE PASSE

- ☐ Installer un gestionnaire de mots de passe (Bitwarden, gratuit)
- ☐ Changer les mots de passe des comptes critiques (messagerie, banque, cloud)
- ☐ Activer la double authentification (2FA) sur la messagerie pro

SAUVEGARDES

- ☐ Vérifier que votre sauvegarde existe et est récente (moins de 24h)
- ☐ Tester la restauration d'un fichier depuis votre sauvegarde
- ☐ Déconnecter le support de sauvegarde du réseau principal

MISES À JOUR

- ☐ Activer les mises à jour automatiques sur tous les postes
- ☐ Vérifier le firmware de votre routeur WiFi professionnel
- ☐ S'assurer que l'antivirus est actif sur tous les postes

ORGANISATION

- ☐ Former les collaborateurs à reconnaître un email de phishing (30 min)
- ☐ Établir une règle : tout virement inhabituel = vérification téléphonique
- ☐ Définir qui peut accéder à quelles données (principe du moindre privilège)

4

Kit Cybersécurité Clé en Main — Programme complet

Auto-diagnostic • Recommandations • Modèles prêts à l'emploi • Checklists

MODULE 1

Mode d'emploi et guide de lecture

Ce kit est conçu pour être utilisé de façon autonome, sans connaissance technique préalable. Suivez les modules dans l'ordre — chacun s'appuie sur le précédent.

ÉTAPE 1

Faites le diagnostic

Répondez honnêtement aux 20 questions du Module 2. Comptez votre score.

ÉTAPE 2

Lisez votre score

Consultez le Module 3 pour interpréter votre résultat et identifier vos priorités.

ÉTAPE 3

Appliquez les fiches

Travaillez les fiches recommandations dans l'ordre de priorité défini par votre score.

ÉTAPE 4

Utilisez les modèles

Personnalisez les modèles de documents (Modules 5 et 6) avec vos informations.

Durées estimées

- Modules 2 et 3 (diagnostic + score) : environ 30 minutes
- Module 4 (fiches recommandations) : 1 à 3 heures selon votre situation
- Modules 5, 6, 7 (documents et checklists) : 1 à 2 heures par document

Ce kit vous donne les bases et les bons réflexes. Il ne remplace pas un audit professionnel sur site pour les situations complexes (données de santé, sous-traitance Défense, incident en cours). Si votre score révèle un niveau de risque élevé, contactez-nous : louisguy.briar@gmail.com

MODULE 2

Auto-diagnostic en 20 questions

Cochez UNE seule réponse par question — celle qui décrit le mieux votre situation réelle aujourd'hui. Notez votre score à la fin.

THÈME A — Mots de passe et accès

Q1. Vos mots de passe professionnels sont :

- ☐ [0 pt] Les mêmes partout ou simples (prénom, date de naissance, 123456...)
- ☐ [1 pt] Différents selon les services mais mémorisés sans outil
- ☐ [2 pts] Complexes et gérés via un gestionnaire de mots de passe (Bitwarden, 1Password...)

Q2. L'authentification à deux facteurs (2FA) est activée :

- ☐ [0 pt] Nulle part
- ☐ [1 pt] Sur quelques services importants (email, banque)
- ☐ [2 pts] Sur tous les services professionnels critiques

Q3. Les comptes de vos anciens collaborateurs ou prestataires sont :

- ☐ [0 pt] Toujours actifs — vous n'avez pas vérifié
- ☐ [1 pt] Partiellement désactivés
- ☐ [2 pts] Systématiquement supprimés dès la fin de collaboration

THÈME B — Sauvegardes

Q4. Vos données professionnelles sont sauvegardées :

- ☐ [0 pt] Pas de sauvegarde régulière
- ☐ [1 pt] Manuellement de temps en temps
- ☐ [2 pts] Automatiquement et régulièrement (quotidien ou hebdomadaire)

Q5. Vos sauvegardes sont stockées :

- ☐ [0 pt] Uniquement sur le même ordinateur ou disque
- ☐ [1 pt] Sur un disque externe rangé au bureau
- ☐ [2 pts] En plusieurs endroits : externe + cloud ou site distant (règle 3-2-1)

Q6. Vous avez testé la restauration de vos sauvegardes :

- ☐ [0 pt] Jamais
- ☐ [1 pt] Il y a plus d'un an
- ☐ [2 pts] Dans les 6 derniers mois

THÈME C — Mises à jour et logiciels

Q7. Les mises à jour de vos systèmes (Windows, macOS, applications) sont :

- ☐ [0 pt] Souvent ignorées ou reportées
- ☐ [1 pt] Faites quand vous y pensez
- ☐ [2 pts] Appliquées rapidement ou automatiquement

Q8. Les logiciels installés sur vos postes sont :

- ☐ [0 pt] Anciens, certains ne sont plus supportés par l'éditeur
- ☐ [1 pt] La plupart à jour, quelques exceptions
- ☐ [2 pts] Tous à jour et listés dans un inventaire

Q9. Un antivirus ou EDR est installé et actif sur tous vos postes :

- ☐ [0 pt] Non
- ☐ [1 pt] Sur certains postes seulement
- ☐ [2 pts] Oui, sur tous les postes avec mises à jour automatiques

THÈME D — Email et phishing

Q10. Face à un email inattendu demandant de cliquer sur un lien ou de payer, vous :

- ☐ [0 pt] Cliquez si l'expéditeur semble connu
- ☐ [1 pt] Vérifiez l'adresse mais vous fiez à l'apparence
- ☐ [2 pts] Contactez l'expéditeur par un autre canal avant d'agir

Q11. Vos collaborateurs ont reçu une sensibilisation au phishing :

- ☐ [0 pt] Jamais
- ☐ [1 pt] Une fois à l'embauche
- ☐ [2 pts] Régulièrement (au moins une fois par an)

Q12. Votre messagerie professionnelle dispose d'un filtre anti-spam/anti-phishing :

- ☐ [0 pt] Non ou vous ne savez pas
- ☐ [1 pt] Oui, celui de base du fournisseur
- ☐ [2 pts] Oui, avec un filtre avancé configuré

THÈME E — RGPD et données personnelles

Q13. Vous savez quelles données personnelles vous traitez et pourquoi :

- ☐ [0 pt] Non, vous n'avez pas fait cet inventaire
- ☐ [1 pt] Partiellement, pour les principaux fichiers
- ☐ [2 pts] Oui, vous avez un registre des traitements à jour

Q14. Vos clients et contacts sont informés de l'utilisation de leurs données :

- ☐ [0 pt] Non
- ☐ [1 pt] Via une mention légale basique sur votre site
- ☐ [2 pts] Via une politique de confidentialité complète et accessible

Q15. En cas de violation de données (fuite, vol), vous sauriez comment réagir :

- ☐ [0 pt] Non, vous n'avez pas de procédure
- ☐ [1 pt] Vaguement, vous appelleriez votre informaticien
- ☐ [2 pts] Oui, vous connaissez l'obligation de notification CNIL sous 72h

THÈME F — Organisation et gouvernance

Q16. Il existe une politique ou des règles de sécurité écrites dans votre structure :

- ☐ [0 pt] Non
- ☐ [1 pt] Des règles informelles, non écrites
- ☐ [2 pts] Un document écrit accessible à tous

Q17. En cas d'incident informatique grave, votre plan de continuité d'activité est :

- ☐ [0 pt] Inexistant
- ☐ [1 pt] Mental — vous savez à peu près quoi faire
- ☐ [2 pts] Documenté et testé

Q18. L'accès à vos locaux et équipements informatiques est :

- ☐ [0 pt] Non contrôlé — tout le monde y accède
- ☐ [1 pt] Partiellement contrôlé
- ☐ [2 pts] Contrôlé : accès nominatifs, postes verrouillés

THÈME G — Réseau et cloud

Q19. Votre réseau Wi-Fi professionnel est :

- ☐ [0 pt] Partagé avec les clients ou visiteurs, même réseau
- ☐ [1 pt] Protégé par un mot de passe simple
- ☐ [2 pts] Séparé du réseau visiteurs, avec un mot de passe fort et WPA3

Q20. Les données stockées dans le cloud (Drive, OneDrive, Dropbox...) sont :

- ☐ [0 pt] Non chiffrées et accessibles sans authentification forte
- ☐ [1 pt] Protégées par un mot de passe uniquement
- ☐ [2 pts] Chiffrées, avec accès contrôlé et 2FA activé

CALCULEZ VOTRE SCORE Additionnez les points de toutes vos réponses cochées (0, 1 ou 2 par question). TOTAL : ____ / 40 points

Tableau de synthèse par thème

THÈME	VOTRE SCORE /6	PRIORITÉ
A — Mots de passe	___ / 6	☐ Urgent ☐ Important ☐ OK
B — Sauvegardes	___ / 6	☐ Urgent ☐ Important ☐ OK
C — Mises à jour	___ / 6	☐ Urgent ☐ Important ☐ OK
D — Email & phishing	___ / 6	☐ Urgent ☐ Important ☐ OK
E — RGPD	___ / 6	☐ Urgent ☐ Important ☐ OK
F — Organisation	___ / 6	☐ Urgent ☐ Important ☐ OK
G — Réseau & cloud	___ / 6	☐ Urgent ☐ Important ☐ OK

MODULE 3

Interprétation de votre score

0 – 10

NIVEAU CRITIQUE — Risque élevé

Votre structure présente de nombreuses vulnérabilités exploitables. Un incident est probable à court terme. Commencez immédiatement par les Fiches 1 et 2 (mots de passe + sauvegardes). Ces deux actions réduisent 70 % des risques les plus courants.

11 – 22

NIVEAU INTERMÉDIAIRE — Risque modéré

Vous avez des bases mais des lacunes importantes subsistent. Travaillez les 5 fiches dans l'ordre. Portez une attention particulière au RGPD si vous traitez des données de santé ou financières.

23 – 33

NIVEAU CORRECT — Risque maîtrisé

Votre niveau est satisfaisant. Concentrez-vous sur les points où vous avez scoré 0 ou 1. Formalisez vos pratiques avec les modèles du Module 5 pour renforcer votre conformité.

34 – 40

NIVEAU AVANCÉ — Bonne maîtrise

Félicitations, votre niveau de maturité cyber est bon. Utilisez le Module 7 (checklist NIS2/RGPD) pour vérifier votre conformité réglementaire et documenter vos pratiques.

MODULE 4

5 Fiches recommandations détaillées

Chaque fiche est autonome. Travaillez-les dans l'ordre de priorité défini par votre score.

01

Mots de passe & Gestion des accès

⚠ Un mot de passe faible ou réutilisé est la porte d'entrée numéro 1 des cyberattaques. 80 % des violations de données impliquent des identifiants compromis.

Difficulté

Facile

Coût estimé

Gratuit à faible coût

Actions à mener (dans l'ordre)

1. Installez un gestionnaire de mots de passe (Bitwarden est gratuit et open source)
2. Changez tous vos mots de passe professionnels pour des mots de passe uniques de 16+ caractères générés automatiquement
3. Activez le 2FA (double authentification) sur votre messagerie, votre banque en ligne et votre espace cloud
4. Listez tous les comptes professionnels actifs et supprimez les comptes inutilisés
5. Définissez une procédure de départ : tout collaborateur qui part = accès supprimés le jour même

Outils recommandés

- Bitwarden (gratuit) — gestionnaire de mots de passe
- Google Authenticator ou Authy — application 2FA
- Have I Been Pwned (haveibeenpwned.com) — vérifier si vos emails ont fuité

02

Sauvegardes & Plan de reprise

⚠ Sans sauvegarde récente et testée, un ransomware ou une panne disque peut détruire des années de données. 60 % des entreprises victimes d'un ransomware sans sauvegarde déposent le bilan dans les 6 mois.

Difficulté

Facile

Coût estimé

10 à 30 €/mois

Actions à mener (dans l'ordre)

1. Appliquez la règle 3-2-1 : 3 copies de vos données, sur 2 supports différents, dont 1 hors site
2. Configurez une sauvegarde automatique quotidienne (Windows Backup, Time Machine, ou Veeam Free)

3. Choisissez un service cloud chiffré pour la sauvegarde hors site (Backblaze, iDrive, ou Tresorit)
4. Testez la restauration d'un fichier depuis votre sauvegarde — maintenant, pas en cas de crise
5. Documentez la procédure de restauration en termes simples pour que quelqu'un d'autre puisse le faire

Outils recommandés

- Backblaze Personal Backup (~9\$/mois) — sauvegarde cloud automatique
- Veeam Agent Free — sauvegarde Windows gratuite
- FreeFileSync — synchronisation et sauvegarde locale gratuite

03

Mises à jour & Protection des postes

⚠ Les failles de sécurité non corrigées sont exploitées en quelques heures après leur publication. Un système non mis à jour est une cible connue et facile.

Difficulté
Modérée

Coût estimé
Gratuit à 50 €/an

Actions à mener (dans l'ordre)

1. Activez les mises à jour automatiques Windows/macOS et pour tous vos navigateurs
2. Désinstallez les logiciels que vous n'utilisez plus (chaque logiciel inutilisé = une porte potentielle)
3. Vérifiez que votre antivirus est actif, à jour et en version payante sur tous les postes professionnels
4. Activez le pare-feu Windows ou macOS sur tous les postes
5. Chiffrez le disque dur de vos ordinateurs portables (BitLocker sur Windows, FileVault sur Mac) — gratuit et intégré

Outils recommandés

- Windows Defender (intégré, gratuit) — antivirus de base suffisant pour TPE
- Malwarebytes Free — scan ponctuel complémentaire
- Ninite.com — mise à jour groupée de logiciels courants

04

Phishing & Sensibilisation des équipes

⚠ Le phishing est la cause de 90 % des incidents cyber. Un seul clic d'un collaborateur sur un email piégé suffit à compromettre tout le système.

Difficulté
Facile

Coût estimé
Gratuit

Actions à mener (dans l'ordre)

1. Organisez une session de sensibilisation de 30 min avec vos collaborateurs (utilisez les ressources ANSSI gratuites)
2. Apprenez à vérifier une URL suspecte : survolez le lien sans cliquer pour voir la vraie adresse
3. Établissez une règle : tout virement ou changement de coordonnées bancaires demandé par email doit être confirmé par téléphone
4. Activez le signalement des spams dans votre messagerie et formez vos équipes à l'utiliser
5. Abonnez-vous aux alertes cybermenaces de l'ANSSI (gratuit) pour être prévenu des nouvelles campagnes

Outils recommandés

- ANSSI — cybermalveillance.gouv.fr — ressources gratuites de sensibilisation
- Google Phishing Quiz — quiz interactif gratuit pour tester vos réflexes
- MX Toolbox — vérifier la réputation d'un expéditeur email

05

RGD & Conformité des données

⚠ Une violation de données non signalée à la CNIL dans les 72h expose à des sanctions. Les professions traitant des données de santé ou financières sont particulièrement visées.

Difficulté
Modérée

Coût estimé
Gratuit à 20 €/mois

Actions à mener (dans l'ordre)

1. Listez toutes les catégories de données personnelles que vous collectez (clients, prospects, collaborateurs...)

2. Pour chaque catégorie : identifiez la base légale (consentement, contrat, intérêt légitime...) et la durée de conservation
3. Remplissez le registre des traitements du Module 6 — c'est une obligation légale pour toute structure
4. Vérifiez que votre site web dispose d'une politique de confidentialité et d'une gestion des cookies conforme
5. Créez une adresse email dédiée (ex: rgpd@votreentreprise.fr) pour que les personnes puissent exercer leurs droits

Outils recommandés

- CNIL — cnil.fr — modèles officiels gratuits de registre et politique de confidentialité
- Didomi ou Axeptio — gestionnaire de consentement pour site web
- MonAideCyber — outil ANSSI gratuit de diagnostic cyber

MODULE 5

Modèle — Politique de Sécurité

Personnalisez ce modèle avec vos informations. Ce document doit être signé par le dirigeant et accessible à tous les collaborateurs.

POLITIQUE DE SÉCURITÉ DES SYSTÈMES D'INFORMATION [NOM DE L'ENTREPRISE] —
Version 1.0 — Date : __/__/____

Article 1. Objet et champ d'application

La présente politique définit les règles de sécurité informatique applicables à l'ensemble des collaborateurs, prestataires et tiers ayant accès aux systèmes d'information de [NOM DE L'ENTREPRISE]. Elle s'applique à tous les équipements informatiques, qu'ils appartiennent à l'entreprise ou soient utilisés dans un cadre professionnel (BYOD).

Article 2. Règles relatives aux mots de passe

- Tout mot de passe professionnel doit comporter au minimum 12 caractères, incluant majuscules, minuscules, chiffres et caractères spéciaux.
- Il est interdit de réutiliser un mot de passe entre différents services.
- L'utilisation d'un gestionnaire de mots de passe agréé par la direction est recommandée.
- Tout mot de passe doit être modifié immédiatement en cas de suspicion de compromission.
- Il est interdit de communiquer un mot de passe par email, SMS ou oralement.

Article 3. Règles relatives aux équipements

- Tout poste de travail doit être verrouillé dès l'absence de l'utilisateur (raccourci : Win+L ou Cmd+Ctrl+Q).
- Les mises à jour de sécurité doivent être appliquées dans les 48h suivant leur disponibilité.
- L'installation de logiciels non autorisés par la direction est interdite.
- Tout équipement perdu ou volé doit être signalé immédiatement à la direction.
- Le chiffrement du disque dur est obligatoire sur les postes portables.

Article 4. Règles relatives à l'utilisation d'Internet et des emails

- Il est interdit de cliquer sur des liens ou d'ouvrir des pièces jointes provenant d'expéditeurs inconnus.
- Tout email suspect doit être signalé à [RESPONSABLE DÉSIGNÉ] avant tout traitement.
- L'utilisation d'un réseau Wi-Fi public non sécurisé sans VPN est interdite pour accéder aux ressources professionnelles.
- Il est interdit de transmettre des données confidentielles par des messageries non chiffrées.

Article 5. Règles relatives aux données personnelles

- Seules les données strictement nécessaires à l'activité doivent être collectées.
- Les données à caractère personnel doivent être protégées selon les exigences du RGPD.
- Tout incident impliquant des données personnelles doit être notifié à la direction dans l'heure.

Article 6. Procédure en cas d'incident

1. Isoler immédiatement le poste concerné du réseau (débrancher câble Ethernet, désactiver Wi-Fi)
2. Alerter la direction sans utiliser le poste compromis
3. Contacter le prestataire informatique : [NOM + TÉLÉPHONE]
4. Ne pas tenter de résoudre seul — ne pas éteindre le poste (préserve les traces)
5. Si des données personnelles sont compromises : notifier la CNIL dans les 72h (cnil.fr)

Fait à _____, le ____/____/____

Le Dirigeant : _____ Signature : _____

MODULE 6

Registre simplifié des traitements RGPD

Obligation légale pour toute structure. Remplissez une ligne par catégorie de données traitées. Exemples pré-remplis en gris — remplacez-les par vos données réelles.

Finalité	Données traitées	Personnes concernées	Base légale	Durée conservation	Destinataires	Mesures sécurité
Gestion clients	Nom, prénom, email, téléphone, historique achats	Clients actifs et anciens clients	Contrat	3 ans après fin relation	Direction, comptable	Accès restreint, chiffrement
Facturation	Coordonnées, montants, IBAN	Clients et fournisseurs	Obligation légale	10 ans	Expert-comptable, administration fiscale	Chiffrement, accès nominatif
Ressources humaines	Nom, prénom, coordonnées, salaire, bulletins de paie	Collaborateurs	Contrat de travail	5 ans après départ	Direction, expert-comptable, URSSAF	Dossier chiffré, accès DRH uniquement
Prospection commerciale	Nom, email professionnel, société	Prospects	Intérêt légitime	3 ans sans contact	Direction, commercial	CRM sécurisé
Site web / formulaires	Email, message	Visiteurs du site	Consentement	1 an	Hébergeur web	HTTPS, bandeau cookies
_____	_____	_____	_____	_____	_____	_____
_____	_____	_____	_____	_____	_____	_____

Source : CNIL — cnil.fr — Modèle officiel adapté pour TPE/PME

MODULE 7

Checklist conformité RGPD & NIS2

Cochez chaque point complété. Cette checklist peut être présentée à un client, partenaire ou auditeur comme preuve de votre démarche de conformité.

RGPD — Obligations fondamentales

- ☐ Registre des traitements complété et tenu à jour (Module 6)
- ☐ Politique de confidentialité publiée sur votre site web
- ☐ Gestion des cookies conforme sur votre site (bandeau de consentement)
- ☐ Contrats de sous-traitance comportant les clauses RGPD obligatoires
- ☐ Procédure de notification CNIL en cas de violation documentée
- ☐ Procédure de réponse aux demandes des personnes (accès, rectification, suppression)
- ☐ Données de santé : DPO désigné ou recours à un DPO mutualisé

- ☐ Durées de conservation définies et appliquées pour chaque catégorie de données

NIS2 — Vérifiez votre périmètre

La directive NIS2 concerne les entités des secteurs essentiels et importants. Vous êtes potentiellement concerné si vous êtes sous-traitant d'une entité réglementée.

- ☐ Identifier si votre secteur est listé dans les annexes NIS2 (santé, énergie, transport, numérique...)
- ☐ Vérifier si vos donneurs d'ordres vous imposent des exigences de sécurité
- ☐ Mettre en place une gestion documentée des incidents cyber
- ☐ Évaluer et documenter les risques liés à votre chaîne d'approvisionnement numérique
- ☐ Désigner un responsable de la sécurité des systèmes d'information (même partiel)
- ☐ Former la direction aux risques cyber (obligation NIS2 pour les dirigeants)

MODULE 8

Que faire en cas d'incident cyber ?

➤ À IMPRIMER ET AFFICHER dans votre bureau. En cas de crise, vous n'aurez pas le temps de chercher.

Signes qu'un incident est en cours

- Votre ordinateur est lent, des fenêtres s'ouvrent seules ou des fichiers changent d'extension (.locked, .encrypted...)
- Vous voyez un message demandant une rançon sur l'écran
- Vous ne pouvez plus accéder à vos fichiers ou à votre messagerie
- Un collaborateur signale avoir cliqué sur un lien suspect
- Des clients vous signalent avoir reçu des emails frauduleux en votre nom

Les 6 réflexes à avoir IMMÉDIATEMENT

01 ISOLER

Débranchez le poste du réseau (câble Ethernet) et désactivez le Wi-Fi. N'éteignez pas l'ordinateur — cela préserve les traces pour l'analyse forensique.

02 ALERTER	Prévenez la direction et vos collaborateurs via un autre canal (téléphone, pas email). Ne communiquez pas sur les réseaux sociaux.
03 DOCUMENTER	Photographiez les messages d'erreur, notez l'heure, ce que vous faisiez au moment de l'incident. Ces informations sont précieuses pour l'analyse.
04 CONTACTER	Appelez votre prestataire informatique : [NOM] — [TÉLÉPHONE]. Si ransomware : appelez aussi le 3018 (cybermalveillance.gouv.fr).
05 NOTIFIER	Si des données personnelles sont impliquées, vous avez 72h pour notifier la CNIL (notifications.cnil.fr). Dépassé ce délai = sanction automatique.
06 DÉPOSER PLAINTE	Rendez-vous au commissariat ou à la gendarmerie pour déposer plainte. C'est nécessaire pour votre assurance et les poursuites éventuelles.

Contacts d'urgence (à remplir maintenant)

Prestataire informatique	Nom : _____ Tél : _____
Assurance cyber	Nom : _____ N° police : _____ Tél sinistres : _____
ANSSI / Cybermalveillance	cybermalveillance.gouv.fr 3018
CNIL (violation données)	notifications.cnil.fr
Gendarmerie / Police	17 ou gendarmerie locale

Vous souhaitez aller plus loin ?

♦ **KIT AUTONOME**

997 € HT

- ✓ Les 8 modules complets
- ✓ Auto-diagnostic en 20 questions
- ✓ 5 fiches recommandations
- ✓ Modèles et checklists prêts à l'emploi
- ✓ Procédure incident cyber
- ✗ Sans intervention d'expert

★ **PACK EXPERT**

1 997 € HT

- ✓ Tout le Kit Autonome
- ✓ Audit complet par François Briar
- ✓ Plan d'action personnalisé
- ✓ Formation équipe (1h visio)
- ✓ Suivi 30 jours inclus

→ contact@flgb-conseils.fr — François Briar, FLGB Conseils